

Application Review — Top 20 Criteria

Version	1.0
Derived from	Application Review Process and Criteria v1.0 (100 criteria)
Purpose	Rapid-assessment shortlist for portfolio reviews and pre-acquisition checks
Classification	Internal

Purpose

This shortlist contains the 20 most universally applicable and immediately verifiable criteria from the full catalogue. Each criterion can be assessed in a brief stakeholder interview or by inspecting a single artefact. The set covers the domains most frequently decisive in portfolio rationalisation, M&A due diligence, and governance escalations.

Criteria

1. Business Criticality Classification

Rationale: Knowing how critical an application is to operations drives appropriate investment in support, patching, and continuity planning. Ungoverned criticality leads to under-resourced mission-critical systems or over-investment in marginal tools. A defined rating is a prerequisite for risk-proportionate governance.

Assessment Criterion: The application has an assigned and approved business criticality rating (e.g., mission-critical, business-operational, or administrative) recorded in the authoritative application inventory.

2. Business Capability Coverage

Rationale: Every application should support at least one defined business capability. Without this mapping, portfolio rationalisation lacks a factual basis and orphaned tools go undetected. The capability map is the primary lens for identifying redundancy, gaps, and consolidation opportunities.

Assessment Criterion: The application is mapped to at least one documented business capability in the enterprise capability model.

3. Documented Business Value

Rationale: Applications must be justified by measurable outcomes such as cost savings, revenue enablement, or productivity gains. Qualitative claims without supporting evidence are insufficient for investment decisions. A quantified value statement enables direct comparison across the portfolio.

Assessment Criterion: The application has a documented and periodically reviewed business case or value statement that includes at least one quantified benefit metric.

4. Technology Currency

Rationale: Components running past vendor end-of-support can no longer receive certified patches, leaving the application exposed and uninsurable. Currency management is a core discipline of sustainable operations. A 12-month forward horizon gives teams actionable time to plan upgrades.

Assessment Criterion: All major technology components (runtime, framework, database) are on versions with active vendor support for at least the next 12 months.

5. Cloud Readiness

Rationale: Applications that cannot run on cloud infrastructure become blockers as organisations migrate workloads. Early classification against a 6R strategy (rehost, replatform, rearchitect, retain, retire, repurchase) reduces the cost and complexity of future migrations and informs sequencing.

Assessment Criterion: The application has a documented cloud readiness classification with a target state and timeline, aligned to the organisation's defined migration strategies.

6. Authentication and Access Control

Rationale: Weak authentication is the leading cause of enterprise data breaches. Multi-factor authentication and role-based access control are baseline controls required by every major security framework. Absence of either is an immediate compliance and insurance risk.

Assessment Criterion: The application enforces multi-factor authentication for all user access and applies role-based access control with documented roles and a current access review on record.

7. Data Encryption at Rest

Rationale: Unencrypted storage of sensitive data creates catastrophic exposure in the event of a media loss or insider threat. Encryption at rest is mandated by GDPR, ISO 27001, and most sector-specific regulations. The key management discipline is as important as the encryption itself.

Assessment Criterion: All sensitive and personal data stored by the application is encrypted at rest using a currently approved cipher, with encryption keys managed through a dedicated secrets or key management service.

8. Vulnerability Management

Rationale: New vulnerabilities are discovered continuously; an application without a structured patching cadence accumulates exploitable debt. Defined SLAs by severity ensure critical issues are addressed before they are widely exploited. Regular scanning is the baseline mechanism for maintaining visibility.

Assessment Criterion: The application undergoes automated vulnerability scanning at least monthly, and documented SLAs for remediation by severity (e.g., Critical ≤72 h, High ≤14 days) are actively tracked.

9. Data Privacy and GDPR Compliance

Rationale: Processing personal data without a documented legal basis or appropriate safeguards exposes the organisation to regulatory fines and reputational damage. A Data Protection Impact Assessment identifies and mitigates privacy risks before they materialise. This is a non-negotiable requirement for any system handling EU residents' data.

Assessment Criterion: A current Data Protection Impact Assessment is on file, all data processing activities are registered with documented legal bases, and a process exists to fulfil individual rights requests (access,

erasure, portability) within regulatory deadlines.

10. Audit Logging

Rationale: Without comprehensive audit logs, security incidents cannot be investigated and compliance audits cannot be passed. Tamper-evident, centralised logs are required by ISO 27001, SOC 2, and most financial and health regulations. Log retention must align with legal obligations and forensic investigation timelines.

Assessment Criterion: The application generates tamper-evident logs for all security-relevant events (authentication, authorisation changes, data access, administrative actions), and logs are retained in a centralised system for the period required by applicable regulations.

11. Data Ownership and Stewardship

Rationale: Every dataset must have a named owner accountable for quality, classification, access decisions, and compliance. Without ownership, data governance policies cannot be enforced and sensitive data drifts into uncontrolled locations. Ownership must be formal, current, and discoverable.

Assessment Criterion: All data assets managed by the application have a named, current data owner recorded in the data catalogue or application inventory, with documented responsibilities for quality and access governance.

12. Application Lifecycle Classification (TIME)

Rationale: The Gartner TIME model (Tolerate, Invest, Migrate, Eliminate) provides a simple, decision-enabling classification for every application in the portfolio. Without a lifecycle status, budget conversations, roadmap decisions, and retirement planning lack a shared frame of reference. This is the single most actionable portfolio governance data point.

Assessment Criterion: The application has an assigned and reviewed TIME (or equivalent lifecycle) classification recorded in the application inventory, with a rationale and a target review date.

13. Total Cost of Ownership Visibility

Rationale: Decisions about application investment, rationalisation, and migration require a complete view of costs including licences, hosting, support, and internal labour. Partial cost visibility leads to systematically underestimating the benefit of consolidation. TCO is the financial foundation of every portfolio rationalisation business case.

Assessment Criterion: The application has a documented and annually reviewed total cost of ownership figure that covers licence fees, infrastructure, support contracts, and an estimate of internal staff effort.

14. Availability Target and SLA

Rationale: Business-critical applications require formally agreed availability targets so that operations and development teams invest appropriately in resilience. Without a defined SLA, there is no objective basis for incident escalation, capacity planning, or continuity investment. Targets must reflect actual business needs, not defaults.

Assessment Criterion: The application has a documented availability SLA or target (e.g., 99.5% uptime) that has been agreed with business stakeholders and is actively monitored against a reported baseline.

15. Backup and Recovery

Rationale: Data loss from system failure, ransomware, or accidental deletion is only recoverable if tested backups exist. Recovery time and recovery point objectives must be defined in relation to business criticality. Untested backups are not backups.

Assessment Criterion: The application's data is backed up at a frequency consistent with its approved Recovery Point Objective, backups are stored in a separate location, and a recovery test has been completed successfully within the last 12 months.

16. Vendor or Internal Support Model

Rationale: When incidents occur, there must be a clear path to resolution. Expired support contracts, undocumented ownership, or an uncontactable vendor leave teams unable to obtain fixes or guidance under time pressure. Support continuity is a basic operational hygiene requirement.

Assessment Criterion: The application has an active support agreement (vendor contract or documented internal support arrangement) with defined response times, a current contact escalation path, and a named internal owner.

17. Integration Standards Conformance

Rationale: Applications that use bespoke or undocumented integration patterns become barriers to change — any modification requires reverse-engineering the connections. Conformance to agreed API and integration standards reduces coupling and enables independent evolution. Non-conformant integrations must be tracked for remediation.

Assessment Criterion: All integrations with other applications use documented, versioned interfaces (APIs, events, or data feeds) that conform to the enterprise integration standards catalogue, or deviations are registered with an owner and remediation timeline.

18. Code Quality Baseline

Rationale: Codebases with no quality gate accumulate defects and complexity that make every subsequent change slower and riskier. Static analysis tooling provides an objective, continuous measure of maintainability. A defined quality threshold distinguishes managed technical debt from uncontrolled deterioration.

Assessment Criterion: The application's codebase is subject to automated static analysis (or an equivalent quality gate) on each release, and the current quality score meets the team's documented minimum threshold.

19. Architecture Documentation

Rationale: Without up-to-date architecture documentation, onboarding new engineers, performing security reviews, and planning migrations all become disproportionately expensive. Architecture documentation is the institutional memory of a system. Its absence is a key indicator of maintainability risk.

Assessment Criterion: The application has current architecture documentation that describes its key components, data flows, external dependencies, and deployment topology, reviewed or updated within the last 12 months.

20. Licence Compliance

Rationale: Unlicensed or incorrectly licensed software exposes the organisation to audit penalties, legal liability, and forced remediation at the worst possible time. Licence compliance requires active management as user counts, deployment topology, and product editions change. This is an operational and legal risk, not merely an administrative matter.

Assessment Criterion: The application's software licences are documented in the licence management system, actual usage is within the contracted entitlements, and the last reconciliation was completed within the past 12 months.

Coverage Summary

#	Domain
1	Business
2	Business
3	Business
4	Technical
5	Technical
6	Security
7	Security
8	Security
9	Compliance
10	Audit
11	Data
12	Lifecycle
13	Cost
14	Reliability
15	Operations
16	Support
17	Integration
18	Maintainability
19	Documentation
20	Licensing